Ce qu'il ne faut pas faire

- Dupliquer et conserver de manière excessive les données personnelles concernées par le traitement au sein des journaux (ex. : y enregistrer les mots de passe ou leur empreinte (ou « *hash* ») lors de l'authentification des utilisateurs).
- Utiliser les informations issues des dispositifs de journalisation à d'autres fins que celles de garantir le bon usage du système informatique (ex. : utiliser les traces pour compter les heures travaillées est un détournement de finalité, puni par la Loi).
- Conserver les traces sans limite de durée.

POUR ALLER PLUS LOIN

- Voir la recommandation de la CNIL relative à la journalisation[73].
- **Faire participer l'utilisateur à la surveillance des opérations** faites sur son compte et ses données (ex. : proposer un récapitulatif des trois dernières connexions). Privilégier une surveillance automatique des journaux, couplée à une configuration adaptée des alertes.
- **Mettre en place une enclave de collecte** centralisant les journaux d'évènements de l'ensemble du système d'information afin d'empêcher toute altération de ceux-ci.
- L'ANSSI a publié des recommandations sur la mise en place d'un système de journalisation[74] et plus spécifiquement des recommandations en environnement Active Directory[75].

73 « La CNIL publie une recommandation relative aux mesures de journalisation », cnil.fr

74 « Recommandations de sécurité pour l'architecture d'un système de journalisation », cyber.gouv.fr

75 « Recommandations de sécurité pour la journalisation des systèmes Microsoft Windows en environnement Active Directory », cyber.gouv.fr